

BEFORE Placeholder

AFTER

KPIs & KRIs (Third-Party Security Program)

Document classification: Internal

Document owner: Third-Party Security Program Owner

Version: 0.1

Effective date: _____

Review cadence: Quarterly (metrics) / Annually (definitions)

1. Purpose

This document defines the Key Performance Indicators (KPIs) and Key Risk Indicators (KRIs) used to measure program adoption, control effectiveness, and third-party risk posture across the supplier lifecycle.

2. Reporting principles

- Metrics MUST be **actionable** (clear owner and decision outcome).
- Metrics SHOULD be **tier-aware** (Critical / Important / Low).
- Metrics MUST be based on **verifiable sources** (intake records, evidence packs, exception register, onboarding checklists).
- Trend over time is preferred over point-in-time snapshots.

3. Cadence and audience

3.1 Operational dashboard (weekly/bi-weekly)

Audience: Security Engineering/Architecture, Procurement, Business Service Owners

Focus: throughput, bottlenecks, overdue actions, onboarding readiness.

3.2 Management dashboard (monthly)

Audience: Senior Technology/Security leader(s), Technology Risk (as applicable)

Focus: critical supplier posture, material gaps, exception profile, resilience readiness.

3.3 Board/committee pack (quarterly, if required)

Audience: Executive governance stakeholders (generic)

Focus: critical supplier coverage, concentration risk, material incidents, residual risk acceptance.

4. KPIs (delivery / program performance)

KPI-1: Tiering coverage

Definition: % of in-scope suppliers with a recorded tier classification.

Target: 100% for Critical/Important; proportionate coverage for Low.

Source: Supplier intake forms + tiering records.

KPI-2: Due diligence completion time (lead time)

Definition: Median days from intake submission to due diligence decision (Approved / Conditional / Deferred).

Target: Trend down while maintaining control quality.

Source: Intake date + decision date in assessment register.

KPI-3: Conditional approvals resolved on time

Definition: % of "Approved with Conditions" actions closed by agreed due date.

Target: $\geq 90\%$ (Critical), $\geq 85\%$ (Important).

Source: Actions log / onboarding checklist.

KPI-4: Secure onboarding pattern adoption

Definition: % of new integrations using approved patterns (SSO, least privilege roles, logging enabled, standard connectivity).

Target: $\geq 90\%$ for Critical; $\geq 80\%$ for Important.

Source: Onboarding readiness checklist / integration pattern record.

KPI-5: Offboarding completeness

Definition: % of offboarded suppliers with confirmed access removal and data return/deletion evidence (where applicable).

Target: 100% for Critical/Important.

Source: Offboarding checklist + confirmation artifacts.

5. KRIs (risk posture / exposure)

KRI-1: Critical supplier assessment currency

Definition: % of Critical suppliers with an assessment completed/renewed within the defined review period.

Target: $\geq 95\%$.

Source: Assessment register with review dates.

KRI-2: Open high-risk gaps on Critical suppliers

Definition: Count of open Critical-supplier gaps rated high severity (as defined by program) past due remediation date.

Target: 0 past-due high severity gaps.

Source: Gap log / remediation tracker.

KRI-3: Exception volume and ageing (Critical)

Definition: Number of active exceptions for Critical suppliers and median age (days) to closure.

Target: Trend down; ageing within agreed bounds; no expired exceptions.

Source: Exception register.

KRI-4: Expired exceptions

Definition: Count of exceptions past expiry date (by tier).

Target: 0.

Source: Exception register.

KRI-5: Privileged access exposure

Definition: Number of suppliers with privileged/administrative access to production, segmented by tier.

Target: Minimise; all Critical suppliers must have documented access paths and compensating controls where required.

Source: Intake + integration records.

KRI-6: Persistent connectivity exposure

Definition: Number of suppliers with persistent network connectivity (VPN/private link) or inbound connectivity, segmented by tier.

Target: Minimise; all such suppliers must be explicitly approved and monitored.

Source: Integration records.

KRI-7: Logging/auditability gaps (Critical)

Definition: % of Critical suppliers where required audit logs (admin/auth, relevant access) are not available/exportable as agreed.

Target: 0% (or formally excepted with compensating controls).

Source: Evidence pack + onboarding validation.

KRI-8: Sub-processor visibility gaps (Critical)

Definition: % of Critical suppliers without an up-to-date sub-processor list and change notification commitment.

Target: 0% (or formally excepted).

Source: Evidence pack + contract terms.

KRI-9: Third-party incidents

Definition: Count of supplier-caused or supplier-impacting security incidents in period, including severity and time-to-notify performance against contract.

Target: Trend down; 100% of Critical incidents notified within contractual commitment.

Source: Incident records + supplier notifications.

KRI-10: Concentration risk (Critical services)

Definition: Count of critical business services reliant on a single Critical supplier with no viable workaround.

Target: Known and managed; remediation plans for material concentrations.

Source: Service mapping / critical supplier list.

6. Metric ownership and actions

Each KPI/KRI MUST have:

- an owner (role title),
- a threshold/target,
- a defined action when threshold is breached (e.g., escalate to TPSR/SRAF, block onboarding, require remediation plan).

Recommended owners:

- Program throughput KPIs: Procurement + TPS Program Owner
- Technical posture KRIs: Security Engineering/Architecture
- Contract/privacy KRIs: Legal Counsel + DPO/Privacy Officer
- Residual risk acceptance KRIs: Senior Residual Risk Acceptor

7. Data sources (minimum)

- Supplier intake forms (``program records``)
- Tiering decision record (``tiering-model/``)
- Evidence pack responses (``evidence-packs/``)
- Gap/remediation tracker (``operational records``)
- Exception register (``program-charter/04-policy-exceptions-standard.md``)
- Onboarding/offboarding checklists (``integration/ops records``)
- Incident records (``security operations records``)